Padronizar Gestão de Contas Administrativas

Item do Processo	Diretriz - Padrão Institucional	Justificativa Técnica e Regra de Segurança
1. Separação de Funções	Restrição absoluta do uso de contas administrativas para navegação na internet, leitura de e-mails pessoais ou tarefas cotidianas. O administrador deve possuir uma conta comum para suas tarefas cotidianas e uma conta diferente para gerenciar o AD.	Aplica o princípio da Segregação de Funções para impedir que o comprometimento de uma conta comum afete a rede inteira.
2. Padrão de Nomenclatura e Senha	As contas administrativas devem seguir padrão próprio e exigir obrigatoriamente senhas com no mínimo 14 caracteres (letras maiúsculas, minúsculas, números e símbolos).	Dificulta acessos indevidos e ataques de força bruta direcionados especificamente aos perfis de maior privilégio do diretório.
3. Menor Privilégio	As permissões concedidas a essas contas devem ser estritamente limitadas ao padrão definido para a função técnica exercida, evitando concessões de privilégios globais permanentes e desnecessários que possam ampliar chances de ataque.	Limita o impacto de falhas operacionais ou uso indevido de credenciais privilegiadas na infraestrutura.
4. Auditoria Contínua de Logs	Todas as ações, acessos e alterações realizados por contas administrativas geram registros de eventos auditáveis de forma contínua. Isso garante a rastreabilidade total e o cumprimento das exigências de governança e segurança.	Garante rastreabilidade total e conformidade com requisitos de segurança e governança exigidos.
5. Ciclo de Vida e Revisão	As contas administrativas de terceiros ou temporárias passam por revisão periódica e desativação imediata após o término da demanda.	Essa medida previne a permanência de acessos privilegiados inutilizáveis que possam servir de porta de entrada para acessos não autorizados.